

Authority Propagation Models: PoP vs PoC and the Confused Deputy Problem

Nicola Gallo

1 December 2025

Abstract

Proof-of-Possession authorization models derive authority from the possession of artifacts such as tokens, credentials, or capabilities. This paper argues that possession is insufficient for discrete execution chains, whether they span multiple services or occur as separated steps within the same machine, because it does not preserve the causal relationship between the origin of a request and the authority exercised at later steps. We introduce Proof-of-Continuity as a minimal authority propagation model in which each execution step must be causally linked to the previous step and may only propagate a non-expansive subset of the authority received from the origin. Under this model, the confused deputy condition cannot be satisfied as valid model behavior: any privilege exercised at a later step must already be present in the origin authority context.

1 Model

We formalize the PIC (Provenance Identity Continuity) Model as follows.

Let P be a finite set of principals, O a set of operations, and R a set of resources. Define a privilege as $(o, r) \in O \times R$.

Each principal p has an associated privilege set:

$$Priv(p) \subseteq O \times R.$$

A request is a message req sent between principals and may contain a payload.

Execution is modeled as a causal chain of steps:

$$\pi = \langle (s_0, C_0), (s_1, C_1), \dots, (s_n, C_n) \rangle$$

where s_0 is the origin step and $C_i \subseteq O \times R$ is the authority context carried at step s_i .

Definition 1 (PIC Model). *A system enforces Provenance Identity Continuity if, for every execution chain π , each transition preserves causal continuity and monotonic authority restriction:*

$$C_{i+1} \subseteq C_i$$

for all i , and every privilege exercised at hop n is causally linked to the origin via a verifiable chain.

Theorem 1 (PIC Safety). *If the PIC Model holds, no execution step can exercise a privilege not present at the origin.*

Proof. By construction, $C_{i+1} \subseteq C_i$ for all i , so $C_n \subseteq C_0$. Thus, any $(o, r) \in C_n$ must also be in C_0 . Therefore, no privilege can be gained beyond the origin authority context.

2 Confused Deputy

Definition 2 (Confused Deputy). *A confused deputy occurs when there exist principals U (user) and D (deputy) such that:*

1. $(o, r) \notin \text{Priv}(U)$,
2. $(o, r) \in \text{Priv}(D)$,
3. U sends a request req to D ,
4. as a consequence of req , D executes (o, r) .

This definition does not depend on implementation details, only on the mismatch of authority and causality.

Classical example (Hardy, 1988). A FORTRAN compiler FORT, installed in the privileged directory SYSX, holds ambient authority to write statistics to (SYSX)STAT. A user invokes the compiler and provides (SYSX)BILL as the debugging output filename. The compiler opens the target for output using its own authority over SYSX, thereby overwriting (SYSX)BILL. The user never possessed this privilege, but the deputy exercised it as a consequence of the user's request.

3 Proof-of-Possession (PoP)

A token t grants a set of privileges:

$$Auth(t) \subseteq O \times R.$$

PoP Semantics. Possession implies usability: if a principal holds t , it may exercise all $(o, r) \in Auth(t)$.

PoP systems constrain authority by artifact possession, but do not, by themselves, require that the exercised authority be a causal continuation of the authority context of the request.

3.1 Authority Mixing

Assume:

$$(write, r) \notin Priv(U) \tag{H1}$$

$$(write, r) \in Priv(D) \tag{H2}$$

Here U is the user and D is a deputy.

In a possession-based model, a deputy may hold multiple authority sources: its own ambient privileges, delegated tokens, bearer credentials, or other artifacts. The model authorizes an operation by checking whether some possessed authority source grants the requested privilege.

Theorem 2 (PoP admits authority mixing). *In a possession-based model, if an executor may select authority from any artifact or ambient privilege it holds independently of the request authority context, then the confused deputy condition is admissible in the model.*

Proof. Let a request originate from an authority context that does not contain (o, r) . Let the executor hold another authority context, artifact, or ambient privilege that does contain (o, r) .

In a PoP model, authorization depends on the possession of an artifact or privilege granting (o, r) , not on whether that authority is a continuation of the request authority context. Therefore the model permits an execution in which the request causally triggers (o, r) while (o, r) is absent from the request authority context. This is exactly the confused deputy condition.

This applies to artifact-based delegation models whenever authorization is derived from possession rather than continuity: JWTs, sealed capabilities, cryptographic bearer credentials, and related mechanisms.

4 Proof-of-Continuity (PoC / PIC)

Execution is a causal chain:

$$s_0 \rightarrow s_1 \rightarrow \cdots \rightarrow s_n.$$

Let $C_i \subseteq O \times R$ denote the authority context carried by execution step s_i .

We write:

$$PoR(s_i, s_{i+1})$$

when s_{i+1} is a valid causal continuation of s_i within the same execution lineage.

Definition 3 (Proof of Continuity). *A Proof-of-Continuity transition is valid iff:*

$$PoC(s_i, C_i, s_{i+1}, C_{i+1}) \iff PoR(s_i, s_{i+1}) \wedge C_{i+1} \subseteq C_i.$$

The first condition proves causal relationship. The second condition proves monotonic authority restriction.

Thus, each hop transfers only:

$$C_{i+1} \subseteq C_i. \tag{C1}$$

Let:

$$\pi = \langle (s_0, C_0), (s_1, C_1), \dots, (s_n, C_n) \rangle.$$

4.1 Authorization Rule

(o, r) is authorized at the final hop iff:

$$(o, r) \in \bigcap_{i=0}^n C_i.$$

Since the chain is monotonic decreasing:

$$C_n \subseteq C_{n-1} \subseteq \cdots \subseteq C_0,$$

we have:

$$\bigcap_{i=0}^n C_i = C_n.$$

Thus no hop may acquire authority not already present at the origin.

Lemma 1 (Irreversible loss of authority). *If $(o, r) \notin C_j$ for some hop j , then $(o, r) \notin C_k$ for all $k \geq j$.*

Proof. By monotonicity, $C_k \subseteq C_j$ for all $k \geq j$. Therefore, if $(o, r) \notin C_j$, then (o, r) cannot appear in any later authority context C_k .

5 Safety Property

Definition 4 (Origin-bounded authority). *A model enforces origin-bounded authority if every executable privilege at hop n was originally granted at hop 0.*

Theorem 3 (PoC prevents confused deputy). *If $C_0 = \{(convert, r)\}$, then $(write, r)$ can never be authorized within the same execution chain.*

Proof. $(write, r) \notin C_0$ and $C_{i+1} \subseteq C_i$ for every transition. Thus $(write, r) \notin C_n$.

6 Elimination of the Confused Deputy

The confused deputy condition requires an authority mismatch: a privilege absent from the authority context of the request is nevertheless exercised as a consequence of that request.

PIC eliminates this condition as valid model behavior.

Theorem 4 (Confused deputy is invalid under PIC). *In any system satisfying PIC monotonicity $C_{i+1} \subseteq C_i$ and origin-bounded authority $C_n \subseteq C_0$, the confused deputy conditions cannot be jointly satisfied as valid behavior within the model.*

Proof. The confused deputy condition requires:

$$(o, r) \notin C_0 \quad \text{and} \quad (o, r) \in C_k \text{ for some } k > 0.$$

But PIC enforces:

$$C_k \subseteq C_0 \quad \forall k.$$

Thus if $(o, r) \notin C_0$, it cannot appear in any C_k . The privilege mismatch required for a confused deputy is impossible within a valid PIC execution.

Interpretation. Authority in PIC is not something that a subject merely *has*; it is a continuity property of the execution chain. Since no hop may introduce or reinterpret authority absent at the origin, a confused-deputy execution may still be attempted physically, but it cannot be accepted as valid behavior within the PIC model.

7 Discussion

PoP systems conflate authority and possession, enabling authority mixing across execution contexts. PIC/PoC systems instead propagate only non-expansive subsets of authority along a causally verified execution chain.

Proof of Possession proves artifact control. Proof of Relationship proves execution relationship. Proof of Continuity proves authority continuation.

The resulting security invariant is simple: no downstream service can perform, as part of a valid execution chain, an operation that was not authorized at the origin.

Related Work

The confused deputy problem was introduced by Hardy (1988). This paper focuses narrowly on the confused deputy as a mismatch between authority and causality, and compares possession-based authority propagation with provenance-continuity-based authority propagation.

The PIC model is developed independently in Gallo (2025), where Provenance Identity Continuity is introduced as a general model for distributed execution systems.

Acknowledgments

The author used automated language assistance tools for grammar and phrasing. All conceptual contributions, models, and proofs are solely the author's.

References

1. N. Hardy. “The Confused Deputy.” *ACM Operating Systems Review*, 1988.
2. N. Gallo. “PIC Model — Provenance Identity Continuity for Distributed Execution Systems.” Zenodo, 2025. <https://zenodo.org/records/17777421>.